ConFoo 2026

A standard for interoperability between two closed systems where one user owns data on each application

October 2012

Martin Legris

Sample Use Cases

An app that allows concert discovery, needs access to your contacts on facebook.

data

functionality

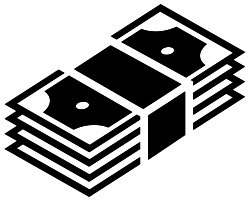
data

Your employer's accounting app needs access to your spending records on your credit card.

data

functionality

data



OAuth2 Terminology

Scope	Associated with one authorization, deciding what to allow access to
Authorization Code	Granted immediately after authorization, to be converted into an Access Token.
Access Token	Security Token that grants an external system access to data on behalf of a user. 60 minutes lifespan
Refresh Token	Seurity Token that allows the external system to get new Access Tokens. Can expire or not.
Callback URI	The URI that receives the result of the access grant by the user.
Rate Limiting	Limiting the number of calls per minute per client app/user combination.

RESOURCE OWNER
user

CLIENT
the application

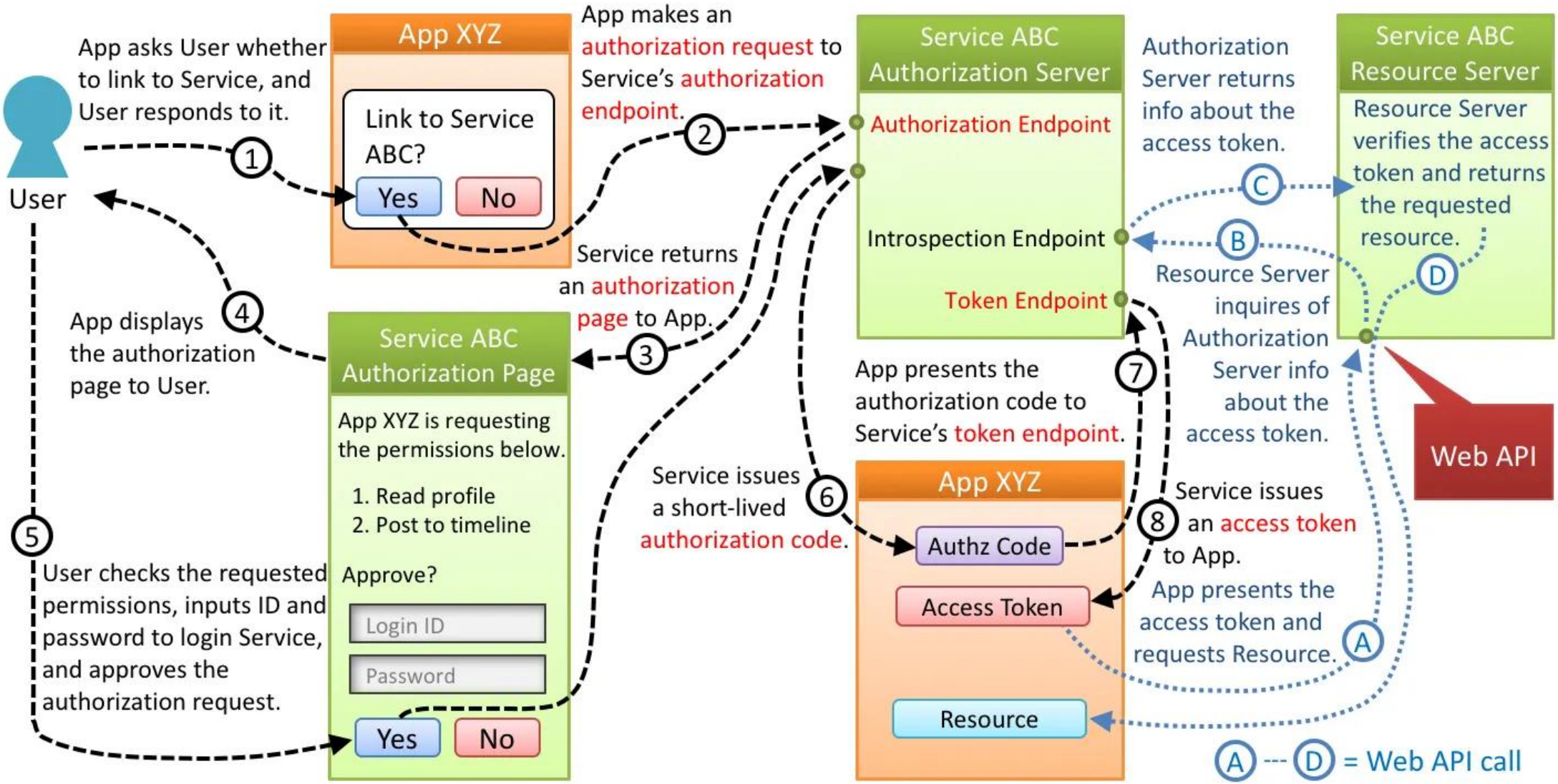
AUTH SERVER

RESOURCE SERVER
api

User owned data

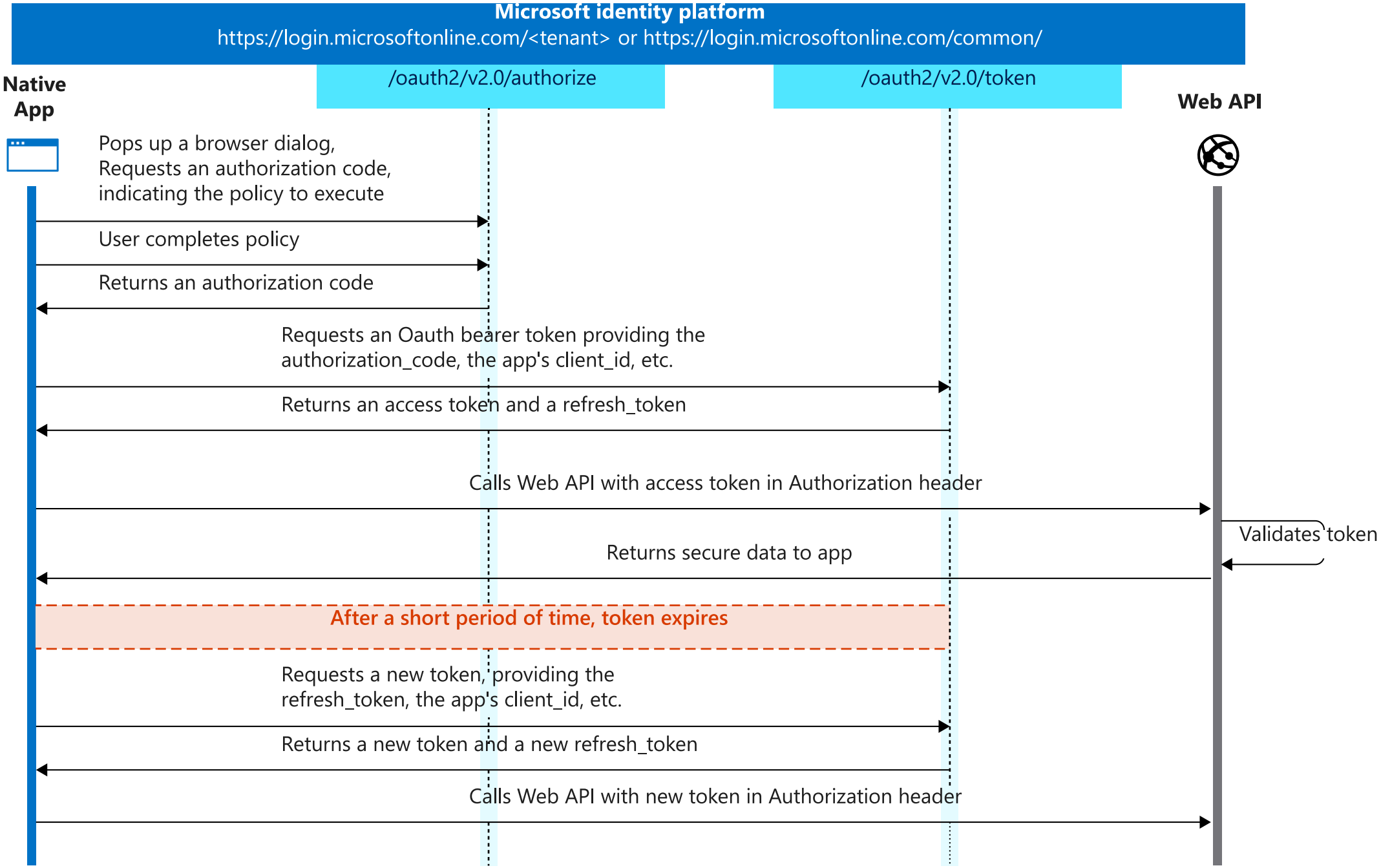
Access Grant

Authorization Code Flow (RFC 6749, 4.1)



© 2017 Authlete, Inc. https://www.authlete.com/

Microsoft's Authorization Code Flow



OAuth 2 - Authorization Screens

Authorize application

Example App by @oauth2 would like permission to access your account

Review permissions

Delete repositories
Ability to delete any adminable repository

Notifications
Read access

Gists
Read and write access

This application will be able to read and write your public and secret gists.

Learn more

Example App

This is an example app used by Aaron Parecki's "OAuth 2.0 Servers" book.

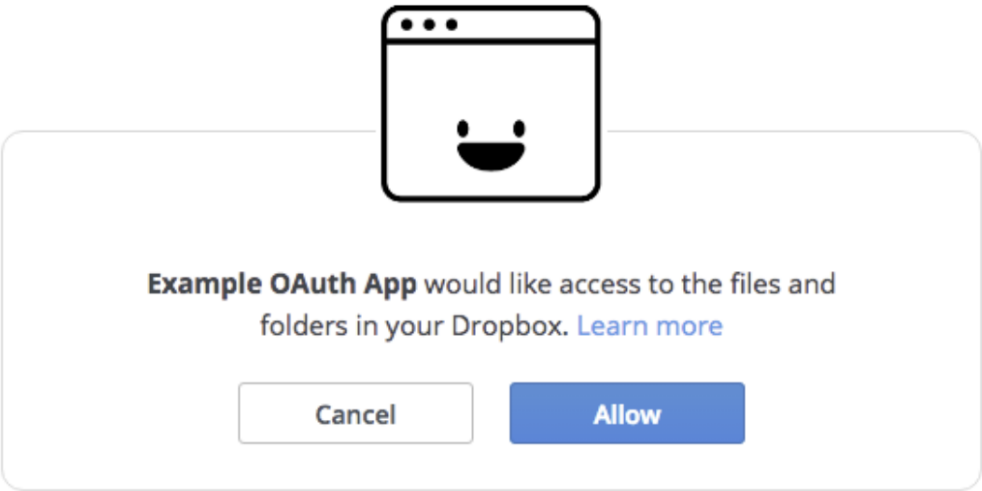
Visit application's website

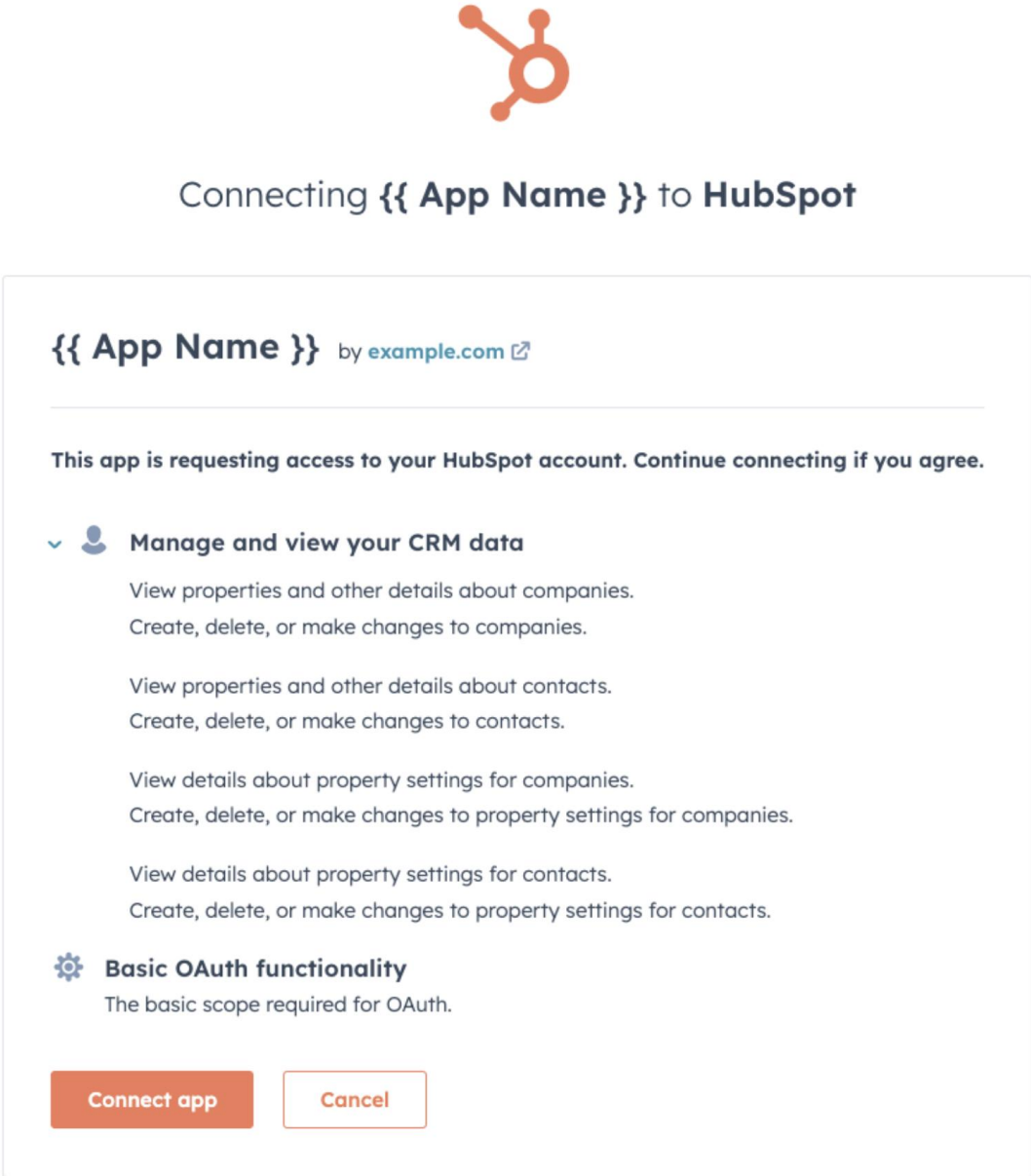
Learn more about OAuth

Important Elements

- User Avatar (self recognition)
- Host Application Icon
- Client Application Icon
- Description of allowed scope

OAuth 2 - Authorization Screens





Oauth Authorization Screens

Microsoft

priya.nayar@adatum.com

Let this app access your info? (1 of 1 apps)

Contoso, Inc.

ContosoApp needs your permission to:

Open OneDrive files
ContosoApp will be able to open OneDrive files, including files shared with you.

Maintain access to data you have given ContosoApp access to
Allows ContosoApp to see and update the data you gave it access to, even when you are not currently using the app. This does not give ContosoApp any additional permissions.

Accepting these permissions means that you allow this app to use your data as specified in their terms of service and privacy statement. You can change these permissions at https://microsoft.com/consent. Show details.

Sign in

Sign in with Google

Canva

Sign in to Canva

martin.legris@gmail.com

Google will allow Canva to access this info about you

Satya Blu
Name and profile picture

martin.legris@gmail.com
Email address

Review Canva's Privacy Policy and Terms of Service to understand how Canva will process and protect your data.

To make changes at any time, go to your Google Account.

Learn more about Sign in with Google.

Cancel | Continue

Microsoft's Many Domains :: Added Complexity

Microsoft — many domains

https://api.powerbi.com	config	access_token	scopes
https://management.azure.com	config	access_token	scopes
https://login.microsoftonline.com	config	access_token	scopes
https://login.windows.net	config	access_token	scopes
https://graph.microsoft.com/.default	config	access_token	scopes

Google — single domain

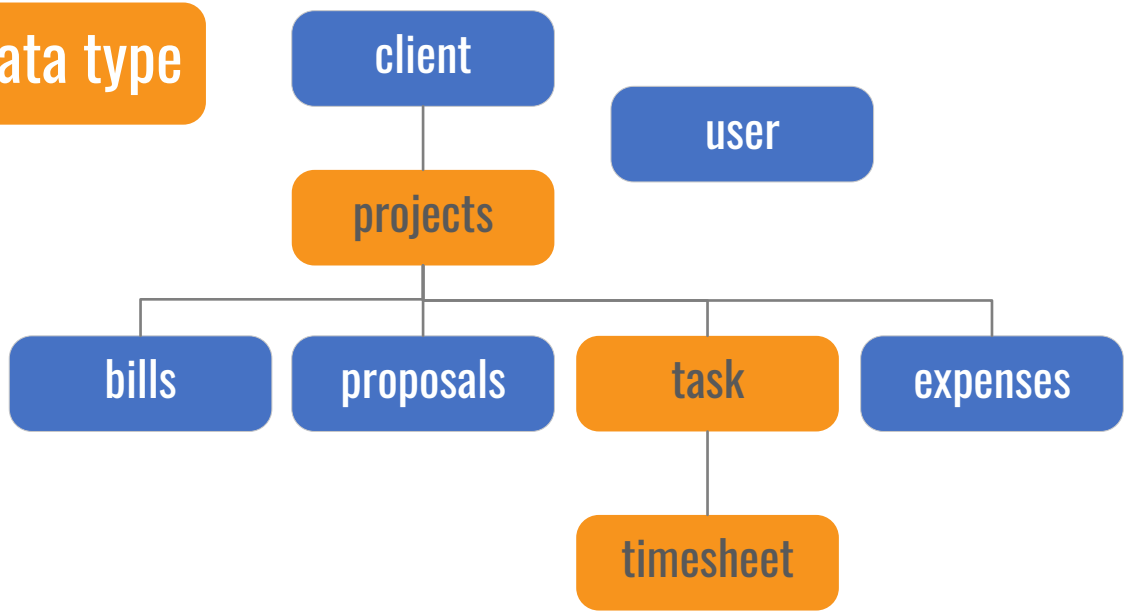
https://accounts.google.com	config	access_token	scopes

What are scopes?

1 What data is accessible

2 What operations are allowed on each data type

projects	read
task	read
timesheet	write



Scope Examples : HubSpot

HubSpot

150 + scopes

Scope	Description	Provides access to	Required account tier
`cms.domains.read`	List **connected domains** in an account.	CMS API	Any account
`cms.domains.write`	Create, update, and delete **connected domains**.	CMS API	Any account
`cms.functions.read`	View all **Content Hub serverless functions**, any related secrets, and function execution results.	CMS API	***Content Hub*** *Enterprise*
`cms.functions.write`	Grants access to write **Content Hub serverless functions** and secrets.	CMS API	***Content Hub*** *Enterprise*
`cms.knowledge_base.articles.read`	View details about knowledge articles.	CMS API	***Service Hub*** *Professional* or *Enterprise*
`cms.knowledge_base.articles.write`	Grants access to update knowledge articles.	CMS API	***Service Hub*** *Professional* or *Enterprise*
`cms.knowledge_base.articles.publish`	Grants access to update and publish knowledge articles.	CMS API	***Service Hub*** *Professional* or *Enterprise*

https://developers.hubspot.com/docs/apps/legacy-apps/authentication/scopes

Scope Examples : Gmail

Gmail

https://developers.google.com/identity/protocols/oauth2/scopes

Scope code	Description	Usage
`https://www.googleapis.com/auth/gmail.addons.current.action.compose`	Manage drafts and send emails when you interact with the add-on.	Non-sensitive
`https://www.googleapis.com/auth/gmail.addons.current.message.action`	View your email messages when you interact with the add-on.	Non-sensitive
`https://www.googleapis.com/auth/gmail.addons.current.message.metadata`	View your email message metadata when the add-on is running.	Sensitive
`https://www.googleapis.com/auth/gmail.addons.current.message.readonly`	View your email messages when the add-on is running.	Sensitive
`https://www.googleapis.com/auth/gmail.labels`	Create, read, update, and delete labels only.	Non-sensitive
`https://www.googleapis.com/auth/gmail.send`	Send messages only. No read or modify privileges on mailbox.	Sensitive

Scope Examples : YouTube

YouTube

https://developers.google.com/identity/protocols/oauth2/scopes

Scope	Description
`https://www.googleapis.com/auth/youtube`	Manage your YouTube account
`https://www.googleapis.com/auth/youtube.channel-memberships.creator`	See a list of your current active channel members, their current level, and when they became a member
`https://www.googleapis.com/auth/youtube.force-ssl`	See, edit, and permanently delete your YouTube videos, ratings, comments and captions
`https://www.googleapis.com/auth/youtube.readonly`	View your YouTube account
`https://www.googleapis.com/auth/youtube.upload`	Manage your YouTube videos
`https://www.googleapis.com/auth/youtubepartner`	View and manage your assets and associated content on YouTube
`https://www.googleapis.com/auth/youtubepartner-channel-audit`	View private information of your YouTube channel relevant during the audit process with a YouTube partner

Scope Examples : GitHub

https://docs.github.com/en/apps/oauth-apps/building-oauth-apps/scopes-for-oauth-apps

GitHub

35 scopes

`(no scope)`	Grants read-only access to public information (including user profile info, repository info, and gists)
`repo`	Grants full access to public and private repositories including read and write access to code, commit statuses, repository invitations, collaborators, deployment statuses, and repository webhooks. **Note:** In addition to repository related resources, the `repo` scope also grants access to manage organization-owned resources including projects, invitations, team memberships and webhooks. This scope also grants the ability to manage projects owned by users.
`repo:status`	Grants read/write access to commit statuses in public and private repositories. This scope is only necessary to grant other users or services access to private repository commit statuses *without* granting access to the code.
`repo_deployment`	Grants access to deployment statuses for public and private repositories. This scope is only necessary to grant other users or services access to deployment statuses, *without* granting access to the code.

Offline Access, Refresh Tokens

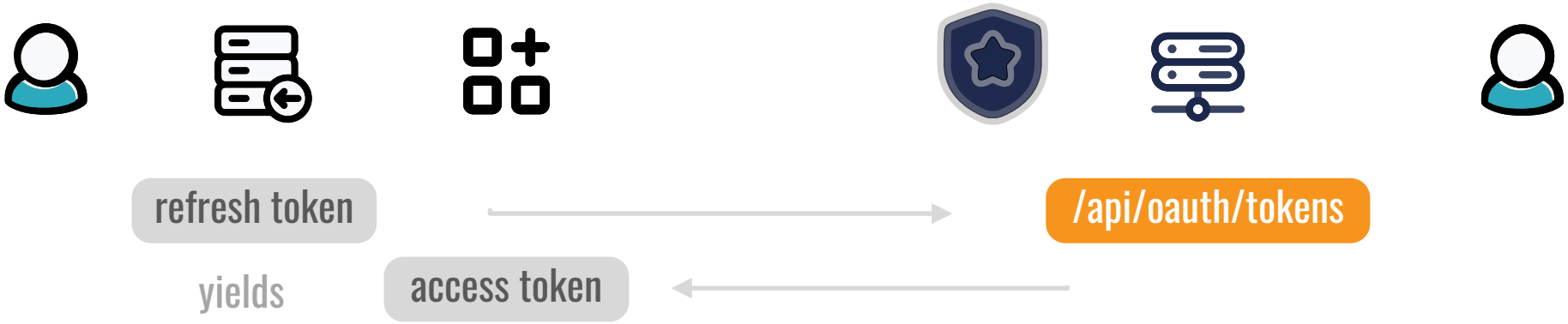
Microsoft

scopes

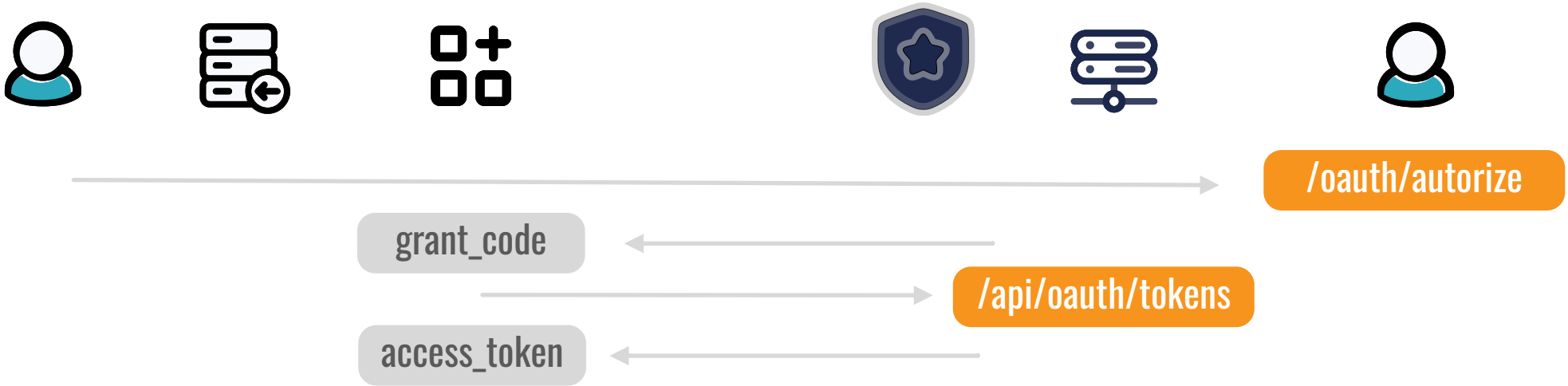
offline_access

This scope value requests that an OAuth 2.0 Refresh Token be issued that can be used to obtain an Access Token that grants access to the End-User's UserInfo Endpoint even when the End-User is not present (not logged in).

Offline Access Enabled (refresh_token) - Less Secure



Offline Access Disabled (~~refresh_token~~) - More Secure



OAuth2 Client :: Generalizing Client

service_provider
- name
- logo
- code

oauth_entity
- base_url
- authorize_url
- token_request_uri
- scope
- client_secret
- client_id
- callback_uri
- technicalities
- rpm

oauth_call
- name
- url
- method
- ttl
- user_required
- random_credentials

oauth_call_param
- name
- transport
- type
- default_value

unique endpoint `/api/call/{provider_name}/{call_name}`

all parameters by GET

mapped to proper transport

automatic credential acquisition

OAuth2 Client :: Token Manager

Thread safe

acquire access token

cache access **user** x **token** x **expiry**

oauth2 configuration

token_request_uri | base_url | authorize_url

scope | client_secret | client_id | callback_uri

technicalities

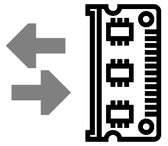
oauth2 configuration

refresh_token

x

x

access_token



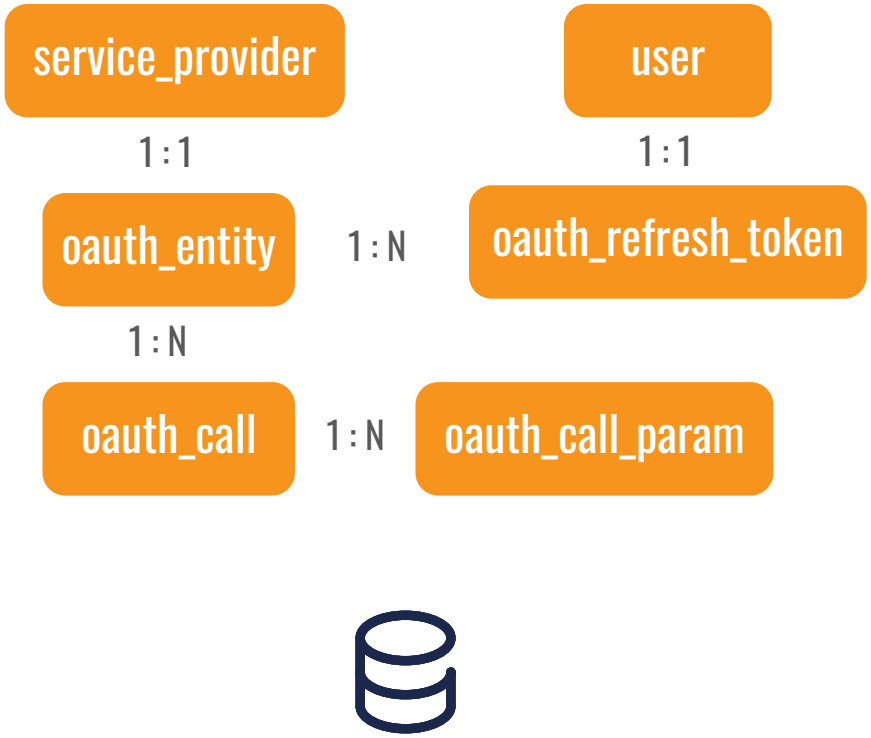
OAuth2 Client :: Generalizing Client

/api/call/{provider_code}/{call_name}

params values + user	generate signature	service_provider	oauth_call
cached ?	get from cache		
(user + refresh_token) ?	get access_token		
(~~user~~ + random credentials) ?	get random access_token		
access_token ?	generate okHttp request	oauth_call	oauth_call_param
rpm ?	execute request		
success ?	set to cache		

https://troove.app/api/call/DEZR/artistSearch?artist=Rise%20Against
https://troove.app/api/call/LFM/artistInfo?artist=Rise+Against

OAuth2 Client :: Data Structure Overview



o_auth_call_cache

SPFY:ArtistSearch + Hash of Parameters

OAuth2 Client :: Data Structure Details

service_provider

- id
- code
- name
- logo_url

oauth_entity

- id
- code
- provider_id
- base_url
- request_uri
- token_request_uri
- client_id
- client_secret
- scope
- callback_uri
- token_basic_auth
- token_params
- request_per_minute

oauth_call

- id
- oauth_entity_id
- method
  - get
  - post
  - put
  - delete
- url
- mapping
- ttl

oauth_call_param

- id
- oauth_entity_id
- name
- transport
  - query
  - body
  - path
  - headers
- type
- value

oauth_refresh_token

- id
- entity_id
- user_id
- refresh_token
- external_id
- expiry

OAuth2 Client :: OAuthEntity Example – Obvious Leap

id	1
code	sq8XBTusfvf5VYw
provider_id	1
base_url	https://time.obviousleap.co/api/
request_uri	https://time.obviousleap.co/oAuth2/
token_request_uri	https://time.obviousleap.co/api/oAuthToken
client_id	ER98pnReGE3RQQMLE9w
client_secret	{...}
scope	timesheet.read client.read project.read
callback_uri	https://troove.app/api/oAuthResponse/sq8XBTusfvf5VYw
token_basic_auth	false
token_params	redirect_uri scope client_id client_secret
request_per_minute	n/a

+

oauth_entity

OAuth2 Client :: OAuthEntity Example - Spotify

id	3
code	WMQqnTsSWCfrS9Cf8TA
provider_id	2
base_url	https://api.spotify.com/v1/
request_uri	https://accounts.spotify.com/authorize
token_request_uri	https://accounts.spotify.com/api/token
client_id	b343909a9b754f6b829d794d2ac23c5f
client_secret	{...}
scope	user-read-private user-read-email streaming user-top-read user-read-recently-played {...}
callback_uri	https://troove.app/api/oAuthResponse/WMQqnTsSWCfrS9Cf8TA
token_basic_auth	true
token_params	redirect_uri
request_per_minute	n/a

oauth_entity

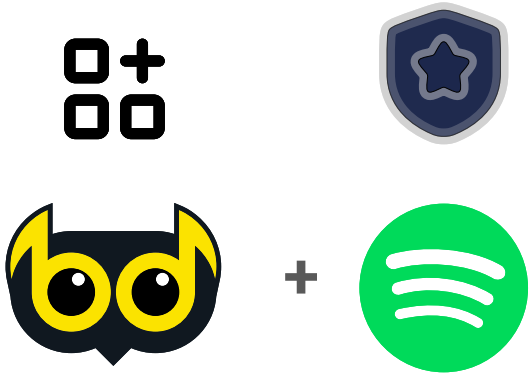
OAuth2 Client :: OAuthCall Example - Spotify

oauth_call

id	14
name	artistSearch
oauth_entity_id	3
url	search
method	GET
mapping	n/a
ttl	604,800
user_required	true
random_credentials	false

oauth_call_param

id	1
name	q
oauth_call_id	14
transport	query
type	string
value	NULL



oauth_entity

OAuth2 Client :: Debug Utility

Pub/Sub

provider call

GET https://api.spotify.com/artistSearch 200 47ms

CHANNEL

SPFY:ArtistSearch

{provider_code} : {call_name}

REQUEST
HEADERS
GET PARAMS
PAYLOAD

RESPONSE
HEADERS
PAYLOAD

Debug/Log Broadcast ON OFF

client x provider

OAuth2 Server :: Data Structure

client_user_oauth

- client_id
- client_code
- client_secret
- application_name
- application_url
- callback_uri
- scope
- activated
- created_on
- revoked
- revoked_on

client_grant_token

- oauth_id
- user_id
- token
- code
- created_at
- claimed
- expires
- successful_requests
- error_requests
- denied_requests

client_refresh_token

- oauth_id
- token
- created_at
- expires
- uses

client

- name
- code
- logo_url

scope

- name
- code
- description
- icon_url

OAuth2 Server :: Authorization

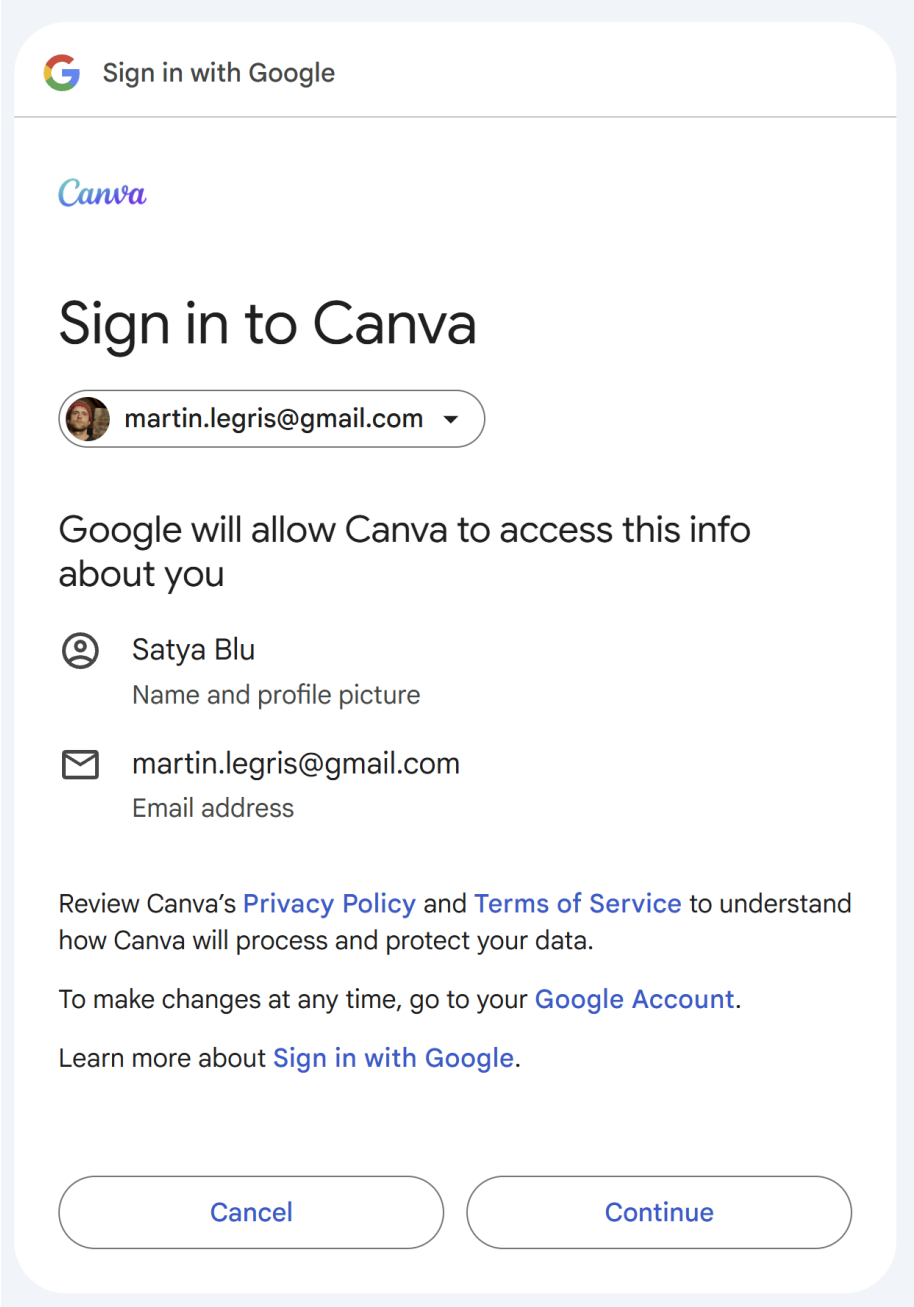
Authorization Screen

GET https://accounts.spotify.com/authorize

- client_id: b343909a9b754f6b8
- response_type: code
- redirect_uri: https://troove.app/api/oAuthResponse/...
- scope: user-read-private user-read-email ...

On Success

Calls redirect_uri + authorization code



OAuth2 Server :: Code to Token

Access Token

POST https://accounts.spotify.com/api/token
application/x-www-form-urlencoded

- grant_type: code
- code: 32nfu4pf9ncli_Kckj%nflk3$
- client_id: lighfj49fjdskjflkj43ncdfafa
- client_secret: Fkjahfe0-vicejcncDDTgids01_=

http

```http
POST /token HTTP/1.1
Host: authorization-server.com
Content-Type: application/x-www-form-urlencoded

grant_type=authorization_code&
code=SplxlOBeZQQYbYS6WxSbIA&
client_id=CLIENT_ID&
client_secret=CLIENT_SECRET&
redirect_uri=REDIRECT_URI
```

On Success

returns: access_token, token_type, refresh_token, expires_in

* some refresh tokens expire; namely microsoft
  you migh not get a refresh token

OAuth2 Server :: Refresh Token to Token

Access Token

POST https://accounts.spotify.com/api/token
application/x-www-form-urlencoded

grant_type	refresh token
refresh_token	dsfkjhkjh42kjb32lkbd
client_id	lighfj49fjdskjflkj43ncdfafa
client_secret	Fkjahfe0-vicejcncDDTgids01_=

On Success

returns: access_token, token_type, refresh_token, expires_in

* some providers only allow refresh_tokens to be used once.

OAuth2 Server :: Important Interfaces

Client Creation Screen

generate or refresh: client_id, client_secret

configure: application_name, application_url, callback_uri * make sure to allow multiple callback_uri's

select: scope

User Grant Management

allow users to see grants given out, their last usages

allow user to revoke grant to an application

OAuth2 Server :: API Access

GET https://time.obviousleap.co/api/timesheet

Authorization: Bearer {access_token}

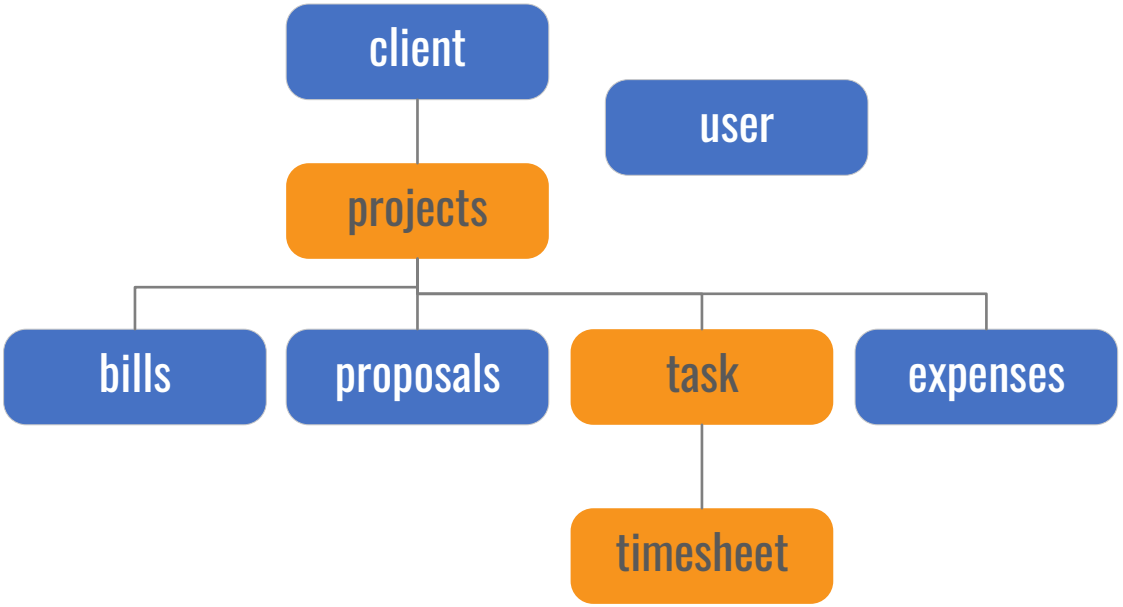
get corresponding client_grant_token client_user_oauth

validate still active access_token expires_in

validate action within scope

track / apply rate limits rate_limits

narrow query to his data user



October 2012

You want more, or need help with your implementation ?

Contact me ☺

Martin Legris

martin.legris@gmail.com